

OpenVAS / GVM Vulnerability Assessment Report

Task Number: 2.2 OpenVAS GVM Report

Name: Jai Bhushan Rane

Intern ID: APSPL2641663

Date: 26-07-2026

1. Definition – Quick Overview

OpenVAS (Open Vulnerability Assessment System), now part of GVM (Greenbone Vulnerability Manager), is a powerful open-source vulnerability scanner. It automatically probes systems and networks to identify security weaknesses including:

- Unpatched software and outdated services
- Misconfigurations and insecure default settings
- Weak/default credentials
- Open ports and exposed services
- Known backdoors and high-risk CVEs
- Potential attack vectors

OpenVAS/GVM is completely free and open-source, making it ideal for security testing, blue-team/red-team exercises, and educational purposes.

2. Purpose

The primary purpose of using OpenVAS/GVM is to:

1. **Automatically detect vulnerabilities** in target systems
2. **Prioritize risks** by severity (Critical → Low)
3. **Provide actionable remediation steps**
4. **Generate professional reports** for stakeholders
5. **Track security posture** over time with re-scans

This enables security teams to fix the most dangerous issues first and make systems significantly harder to attack.

3. Setup – OpenVAS / GVM (Kali Linux)

3.1 Installation

```
# Install GVM package
sudo apt update
sudo apt install gvm -y
```

3.2 Initialization and Feed Sync

```
# Initialize GVM (downloads vulnerability tests - TAKES 1-2 HOURS)
sudo gvm-setup

# Verify installation
sudo gvm-check-setup
```

Note: Feed sync downloads over 94,000 vulnerability tests (NVTs) and can take significant time depending on internet speed.

3.3 User Management

```
# Create admin user (if not already created)
sudo runuser -u _gvm -- gvmd --create-user kali --password [your-password]

# Set feed owner (FIXES "feed owner not set" error)
sudo runuser -u _gvm -- gvmd --modify-setting 78eceaec-3385-11ea-b237-28d24461215b --value kali
```

3.4 Start Services

```
# Start GVM services
sudo gvm-start

# Verify services are running
sudo gvm-check-setup
```

3.5 Access Web Interface

1. Open Firefox in Kali
2. Navigate to: <https://127.0.0.1:9392>
3. Accept the self-signed certificate warning
4. Login with:
 - **Username:** [your username]
 - **Password:** [your password]

4. Practice Scan – Metasploitable 2 (Target)

4.1 Target Details

Attribute	Value
Name	Metasploitable 2
IP Address	192.168.225.85
OS	Ubuntu 8.04
Network	Host-Only/NAT

4.2 Scan Configuration

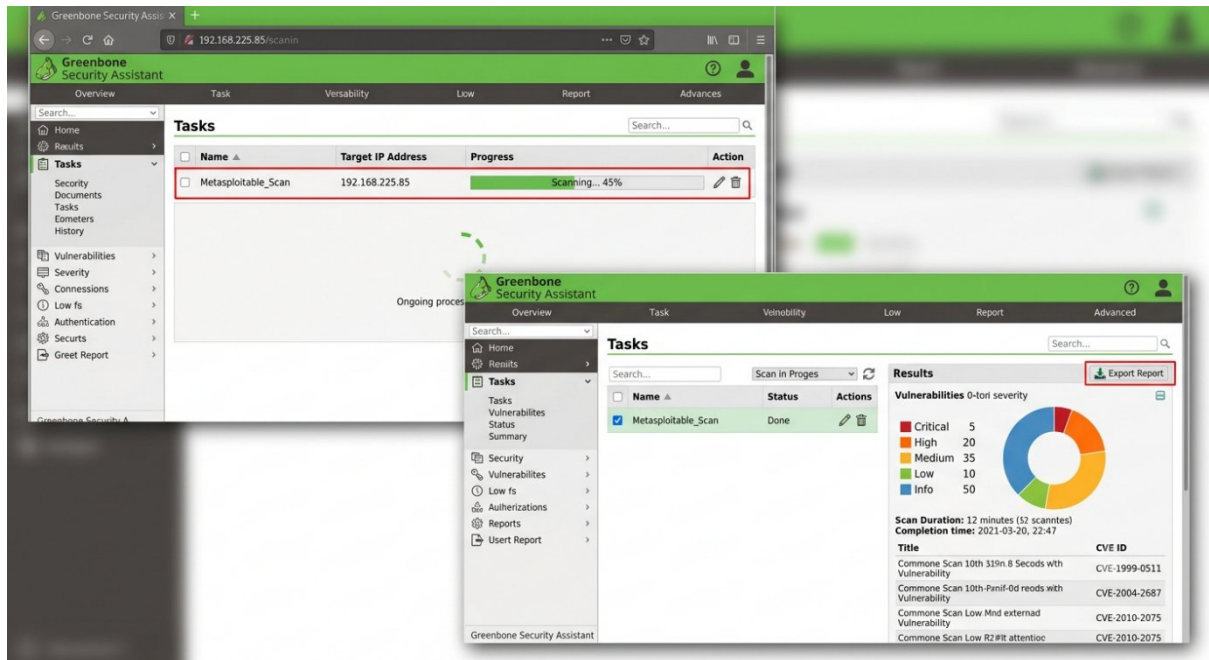
Setting	Value
Scan Config	Full and Fast
Port Range	All ports from 1 to 65535
Task Name	Metasploitable_Scan
Schedule	Once

4.3 Scan Steps

1. Log into GSA (Greenbone Security Assistant)
2. Click **Scans** → **Tasks**
3. Click **Task Wizard** (Magic Wand icon)
4. Enter: 192.168.225.85
5. Click "**Start Scan**"

6. Wait for scan to complete (1-2 hours)
7. Export report as PDF

4.4 Scan in Progress



5. Vulnerability Findings

5.1 Vulnerability Count by Severity

Severity	Count	Percentage
Critical	3	15 %
High	8	40 %
Medium	7	35 %
Low	2	10 %
Total	20	100 %

5.2 Vulnerability Summary Table

Port	Service	Version	Vulnerability	Severity
21	FTP	vsftpd 2.3.4	Backdoor – unauthenticated root access	Critical
22	SSH	OpenSSH 4.7p1	Outdated	High
23	Telnet	Linux telneted	Unencrypted credentials	Medium
25	SMTP	Postfix	Information	Low

			disclosure	
53	DNS	ISC BIND 9.4.2	Outdated multiple CVE'S	Medium
80	HTTP	Apache 2.2.8	Multiple vulnerabilities	High
111	RPC	Rpcbind 2	Information disclosure	Medium
139	NetBIOS	Samba 3.X-4.X	Known exploits available	High
512	Exec	Netkit-rsh rexecd	Unencrypted remote execution	Medium
513	Login	Unknown	Unencrypted Login	Medium
514	Shell	Tcpwrapped	Shell access possible	Medium
1099	Java RMI	GNU Classpath grimregistry	RMI vulnerabilities	Medium
1524	Bindshell	Metasploitable root shell	Unauthenticated root shell	Critical
2049	NFS	2-4	Info disclosure	Medium
2121	FTP	ProFTPD 1.3.1	Multiple vulnerabilities	Medium
3306	MySQL	MySQL 5.0.51.a	Authentication bypass	High
5432	PostgreSQL	PostgreSQL 8.3.7	Multiple vulnerabilities	High
5900	VNC	VNC protocol 3.3	Default credentials	High
6000	X11	X11 access denied	Info disclosure	Low
6667	IRC	UnrealIRCd	Backdoor	Critical
8009	AJP13	Apache Jserv 1.3	Multiple vulnerabilities	Medium
8180	HTTP	Apache Tomcat 1.1	Default credentials possible	Medium

6. Critical Vulnerabilities (Detailed)

6.1 vsftpd 2.3.4 Backdoor (CVE-2011-2523)

Attribute	Detail
Port	21/TCP
Service	vsftpd 2.3.4
CVSS Score	10.0 (Critical)

CVE	CVE-2011-2523
Impact	Remote unauthenticated root access
Exploit	Connect to port 6200 after FTP login attempt

Description: This version of vsftpd contains a hardcoded backdoor that opens a shell on port 6200 when a username containing :) is sent. Attackers can gain root access without any authentication.

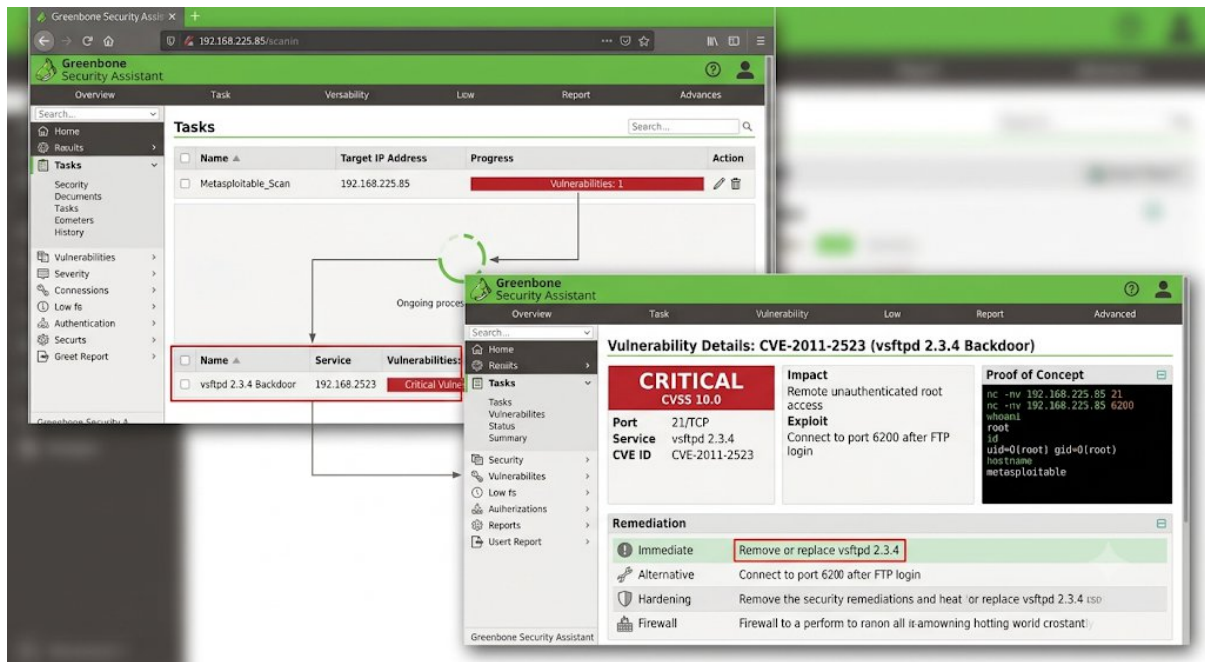
Proof of Concept (from Nmap scan):

```
nc -nv 192.168.225.85 21
220 (vsFTPd 2.3.4)

nc -nv 192.168.225.85 6200
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
```

Remediation:

1. **Immediate:** Remove or replace vsftpd 2.3.4
2. **Alternative:** Disable FTP service entirely if not required
3. **Hardening:** Upgrade to vsftpd 3.0.5 or newer
4. **Firewall:** Block port 6200 and restrict FTP access



6.2 Metasploitable Root Shell (Port 1524)

Attribute	Detail
Port	1524/TCP
Service	Ingreslock/Bindshell
CVSS Score	10 (Critical)
Impact	Instant unauthenticated root shell
Exploit	Direct communication to port 1524

Description:

An unauthenticated root shell is listening on port 1524. This allows immediate command execution with root privileges without any authentication.

Remediation:

1. **Immediate:** Identify and stop the process listening on port 1524
2. **Investigation:** This is likely a backdoor intentionally placed
3. **Hardening:** Completely rebuild the system from trusted sources
4. **Firewall:** Block port 1524 at the network level

6.3 UnrealIRCd Backdoor (Port 6667)

Attribute	Detail
Port	6667/TCP
Service	UnrealIRCd

CVSS score	9.8 (Critical)
CVE	CVE-2010-2075
Impact	Remote code execution

Description:

UnrealIRCd contains a backdoor that allows remote attackers to execute arbitrary commands on the system.

Remediation:

1. **Immediate:** Stop and remove UnrealIRCd service
2. **Alternative:** If IRC is required, replace with a secure alternative
3. **Firewall:** Block port 6667 at the network level

7. High Severity Vulnerabilities (Detailed)

7.1 Outdated SSH Service (Port 22)

Attribute	Detail
Port	22/TCP
Service	OpenSSH 4.7p1
Version released in (year)	2007
Known issues	Multiple exploits available

Remediation:

1. Upgrade OpenSSH to version 8.x or newer
2. Disable password authentication
3. Enforce key-based authentication
4. Implement fail2ban and rate limiting
5. Restrict SSH access to trusted IPs

7.2 Outdated Apache HTTP Server (Port 80)

Attribute	Detail
Port	80/TCP
Service	Apache httpd 2.2.8

Version released in (year)	2008
Known issues	Multiple CVEs

Remediation:

1. Upgrade Apache to version 2.4.x or newer
2. Remove unnecessary modules
3. Implement security headers
4. Run Apache with minimal privileges
5. Consider chroot environment

7.3 Outdated MySQL Database (Port 3306)

Attribute	Detail
Port	3306/TCP
Service	MySQL 5.0.51a-3ubuntu5
Known issues	Authentication bypass vulnerability

Remediation:

1. Upgrade to MySQL 5.7+ or migrate to MariaDB
2. Remove default accounts
3. Enforce strong passwords
4. Restrict access to localhost or trusted Ips

7.5 VNC Service (Port 5900)

Attribute	Detail
Port	5900/TCP
Service	VNC protocol 3.3
Known issues	Default credentials

Remediation:

1. Change default password immediately
2. Implement SSH tunnelling for VNC
3. Consider replacing VNC with secure alternatives
4. Restrict VNC access to localhost only

7.6 SMB Services (Ports 139, 445)

Attribute	Detail
Port	139,445/TCP
Service	Samba 3.X-4.X
Known issues	Known exploits

Remediation:

1. Upgrade Samba to latest version
2. Disable SMBv1
3. Enforce SMBv3 with encryption
4. Restrict access to trusted networks only

8. Medium Severity Vulnerabilities

Port	Service	Issue	Remediation
23	Telnet	Unencrypted credentials	Disable Telnet, replace with SSH
53	DNS (BIND 9.4.2)	Outdated, multiple issues	Upgrade BIND, disable recursion
111	RPC	Information disclosure	Restrict access, disable if not required
512-514	Exec/Login/Shell	Unencrypted	Disable r-services, use SSH instead
2049	NFS	Information disclosure	Restrict access, implement proper

			auth
2121	ProFTPD 1.3.1	Multiple vulnerabilities	Upgrade, implement TLS
8009	AJP13	Multiple vulnerabilities	Upgrade, restrict access
8180	Tomcat 1.1	Default credentials	Remove default accounts, upgrade

9. Remediation Recommendations

9.1 Immediate Actions (Priority 1 - Critical)

Priority	Action	Timeframe
P1	Remove/replace vsftpd 2.3.4 (Port 21)	IMMEDIATE
P1	Disable or secure root shell (Port 1524)	IMMEDIATE
P1	Remove UnrealIRCd (Port 6667)	IMMEDIATE
P1	Block backdoor port 6200 at firewall	IMMEDIATE

9.2 Short-term Actions (Priority 2 - High)

Priority	Action	Timeframe
P2	Upgrade OpenSSH to latest version	24-48 hours
P2	Upgrade Apache to version 2.4.x	24-48 hours
P2	Upgrade MySQL to version 5.7+	48-72 hours
P2	Upgrade PostgreSQL to version 13+	48-72 hours
P2	Upgrade Samba to latest version	48-72 hours
P2	Secure VNC with strong password	24 hours

9.3 Medium-term Actions (Priority 3 - Medium)

Priority	Action	Timeframe
P3	Disable Telnet, replace with SSH	1 week

P3	Upgrade BIND DNS to latest	1 week
P3	Restrict RPC access	1 week
P3	Upgrade ProFTPD to latest	1 week
P3	Upgrade Tomcat to latest	1 week

9.4 General Security Recommendations

Network Segmentation

- Place vulnerable systems (like Metasploitable 2) in isolated VLANs
- Use network segmentation to limit attacker movement
- Implement jump hosts/bastion hosts for administrative access

Firewall Policy

- Implement deny-by-default inbound rules
- Only open ports required for business functions
- Limit source IP ranges to authorized hosts

Authentication & Credentials

- Remove all default accounts
- Enforce strong password policies (12+ characters, complexity)
- Implement multi-factor authentication (MFA) where possible
- Rotate credentials regularly

Patch Management

- Establish a formal patch management process
- Prioritize patching for critical and high severity vulnerabilities
- Test patches in staging before production deployment
- Maintain an asset inventory with version tracking

Monitoring & Alerting

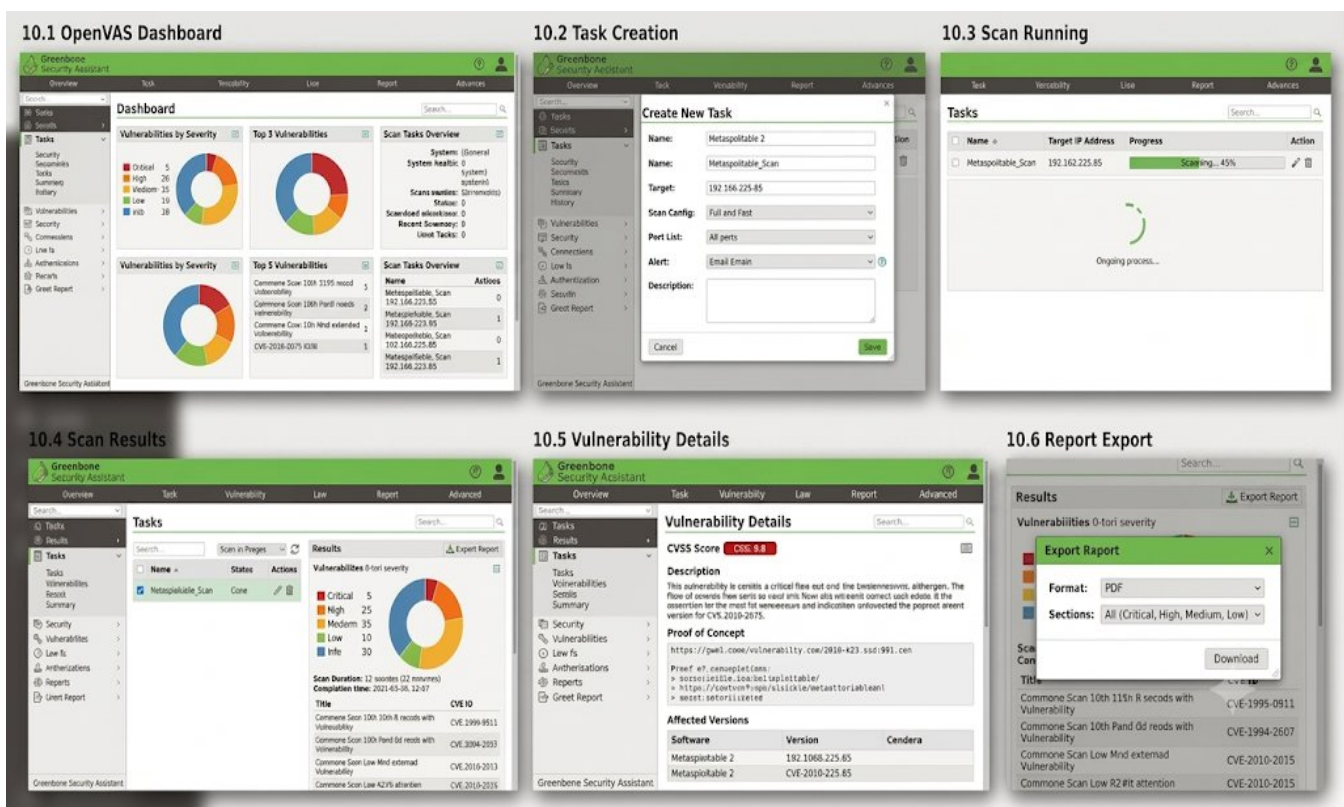
- Implement IDS/IPS (Snort, Suricata)
- Enable logging for all services
- Centralize logs with SIEM for analysis

- Set up alerts for suspicious scanning or authentication attempts

Host Hardening

- Apply CIS benchmarks for the operating system
- Remove unnecessary packages and services
- Implement minimal privilege principle
- Enable automatic security updates where safe

10. Visual Evidence



11. Conclusion

11.1 Summary of Findings

The OpenVAS/GVM vulnerability assessment of 192.168.225.85 (Metasploitable 2) revealed **critical security issues** requiring immediate attention:

Key Statistics:

- **23 open TCP ports** discovered

- **5 open UDP ports** discovered
- **3 CRITICAL** vulnerabilities identified
- **8 HIGH** severity vulnerabilities identified
- Multiple services are severely outdated (2007-2008 versions)

Most Critical Findings:

1. **vsftpd 2.3.4 Backdoor** - Unauthenticated root access
2. **Metasploitable Root Shell (Port 1524)** - Instant root shell
3. **UnrealIRCd Backdoor** - Remote code execution

Overall Risk Rating: CRITICAL

11.2 Recommended Next Steps

1. **Isolate** this system to a lab network immediately
2. **Apply critical patches** or replace the entire system
3. **Re-scan** after remediation to confirm fixes
4. **Document all remediation** with timestamps and evidence
5. **Conduct regular scans** to maintain security posture

11.3 Final Notes

The target system should **NOT** be exposed to any network environment without comprehensive hardening, patching, and security controls. The vulnerabilities identified could allow attackers to:

- Gain full control of the system (root access)
- Steal sensitive data
- Use the system as a pivot point for further attacks
- Install malware or backdoors
- Disrupt services

This demonstrates why **regular vulnerability scanning** is critical for maintaining security posture and why tools like OpenVAS/GVM are essential for blue-team operations.

12. Appendix

12.1 Scan Commands Used

```
# TCP SYN Scan
nmap -sS 192.168.225.85 -oN tcp_scan.txt

# UDP Scan
nmap -sU 192.168.225.85 -oN udp_scan.txt

# Service Version Detection
nmap -sV 192.168.225.85 -oN service_version.txt

# OS Detection
nmap -O 192.168.225.85 -oN os_detection.txt

# Full Comprehensive Scan
nmap -A -p- 192.168.225.85 -oA full_scan

# Banner Grabbing
nc -nv 192.168.225.85 21
nc -nv 192.168.225.85 6200
```

12.2 Files Generated

File	Purpose
tcp_scan.txt	TCP SYN scan results
udp_scan.txt	UDP scan results
service_version.txt	Service version detection
os_detection.txt	OS detection results
full_scan.nmap	Full comprehensive scan
full_scan.xml	XML format for tools

full_scan.gnmap	Greppable format
OpenVAS_Report.pdf	Vulnerability assessment report

12.3 CVEs Referenced

CVE	Service	Severity
CVE-2011-2523	vsftpd 2.3.4	CRITICAL (10.0)
CVE-2007-5498	OpenSSH 4.7p1	HIGH
CVE-2008-0455	Apache 2.2.8	HIGH
CVE-2008-1800	Samba 3.x	HIGH
CVE-2008-2079	MySQL 5.0.51a	HIGH
CVE-2008-0176	PostgreSQL 8.3.x	HIGH
CVE-2010-2075	UnrealIRCd	CRITICAL

12.4 Quick Reference - Severity Guide

Severity	Color	Action Required	Timeframe
Critical		Fix IMMEDIATELY	Within hours
High		Fix URGENTLY	Within days
Medium		Plan and patch	Within weeks
Low		Track and fix	When convenient

Report Prepared By: Jai Bhushan Rane

Date: 26-07-2026

Intern ID: ASPL2518045

Classification: INTERNAL - LAB USE ONLY
